

Cyber Security Operations Platform

Technical Architecture, Data Model and Integration Specification

Document purpose

This document is part of a build-and-operate pack for a modular Cyber Security Operations Platform capable of SOC-as-a-Service, MDR, Managed XDR, sovereign SOC, enterprise private SOC, and MSSP white-label deployments.

1. Architecture objectives

The architecture must support multi-tenant SaaS, sovereign deployment, dedicated enterprise deployment and white-label MSSP mode. It must be integration-first, observable, secure by design, AI-enabled, and able to process both low-volume SME telemetry and high-volume enterprise/security log streams.

2. Reference architecture

Layer	Recommended components	Purpose
Experience layer	Next.js/React portals, analyst console, customer portal, MSP portal	Human workflow, reporting, triage, administration.
API layer	API gateway, REST/GraphQL APIs, webhook endpoints, service-to-service auth	Controlled access to platform functions and integration endpoints.
Identity layer	OIDC/SAML SSO, MFA, RBAC/ABAC, tenant boundary service	Authentication, authorization and separation of duties.
Ingestion layer	Collectors, syslog, API ingestion, connector workers, queues, schema mapper	Reliable receipt of alerts/logs/events from diverse sources.
Event processing layer	Stream processor, deduplication, enrichment, normalization, correlation	Convert raw events into SOC-ready alerts and incidents.
Storage layer	PostgreSQL, object storage, OpenSearch/ClickHouse, vector store	Transactional records, evidence, searchable telemetry and AI retrieval.
Detection layer	Rules engine, Sigma translator, MITRE mapping, coverage engine	Native detections and coverage management.
SOAR layer	Workflow engine, approvals, action connectors, runbook executor	Orchestrated response with safety controls.
AI layer	LLM gateway, prompt templates, retrieval, evaluation, logging, guardrails	Analyst copilot, triage and reporting automation.
Reporting layer	Dashboards, report templates, scheduled exports, compliance packs	Customer, executive, operational and regulatory reporting.
Platform operations layer	Kubernetes/cloud services, CI/CD, secrets, observability, backup/DR	Secure, reliable and maintainable operations.

3. Core data domains

Domain entity	Key fields
Tenant	tenant_id, name, sector, country, residency_mode, service_tier, retention_policy, SLA profile
User	user_id, tenant_id, role, MFA status, SSO identity, status, permissions
Asset	asset_id, tenant_id, hostname, IP, cloud_id, owner, criticality, tags, business service
Identity entity	identity_id, tenant_id, UPN/email, department, privilege level, risk score
Integration	integration_id, tenant_id, vendor, type, status, health, permissions, last_success
Raw event	event_id, tenant_id, source, timestamp, raw payload pointer, checksum, parse status
Normalized event	event_id, tenant_id, class, actor, target, action, outcome, severity, OCSF-like fields
Alert	alert_id, tenant_id, detection_id, severity, confidence, source, status, entities, enrichment
Incident case	case_id, tenant_id, severity, category, stage, SLA timer, owner, related alerts, affected assets
Evidence item	evidence_id, case_id, type, source, hash, chain_of_custody, retention flag
Playbook run	run_id, case_id, playbook_id, approval status, steps, action results, audit records
Report	report_id, tenant_id, type, period, approvals, recipients, generated artifacts

4. Normalized security event model

The platform should adopt an OCSF-inspired normalized schema while retaining raw evidence. This enables analysts, detections and AI workflows to work across Microsoft, firewall, EDR, cloud and custom API sources with a common language.

Field group	Example fields	Notes
Metadata	tenant_id, event_id, source, connector_id, collected_at, observed_at	Tenant and provenance are mandatory.
Classification	class_name, category_uid, activity_name, severity, confidence	Align with OCSF-like taxonomy where practical.
Actor	user, uid, email, IP, process, device, session_id	May map from identity, endpoint or cloud source.
Target	resource, host, file, mailbox, account, cloud_resource	Target may be an asset, identity or data object.
Action/outcome	action, status, outcome, reason, policy	Required for detection and playbook logic.
Threat context	ioc, tactic, technique, malware_family, threat_actor	Enriched during processing.
Evidence	raw_pointer, checksum, parser_version, chain_id	Raw event must be recoverable and defensible.

5. Integration architecture

Connector type	Examples	Pattern
API polling	Microsoft Graph, Defender, CrowdStrike, SentinelOne, vulnerability scanners	Scheduled workers with OAuth/token handling, pagination, rate-limit backoff and checkpointing.
Push/webhook	Cloudflare, custom apps, ticketing systems, customer APIs	Authenticated webhook endpoint, payload validation, idempotency key and schema mapper.
Syslog/CEF/LEEF	Firewalls, routers, appliances, Linux servers	Collector accepts UDP/TCP/TLS syslog and forwards to parser pipeline.
Cloud logs	AWS CloudTrail/GuardDuty, Azure Activity/Defender, GCP audit logs	Provider-native collectors or customer-side forwarders.
Action connectors	Entra disable user, Defender isolate device, firewall block IP, ticket create/update	SOAR-controlled actions with approval, dry-run and rollback notes.

6. Phased integration catalogue

Phase	Integrations	Reason
MVP	Microsoft 365, Entra ID, Defender, syslog, webhook/API, email/Teams, Jira/ServiceNow basics	High market coverage and enough telemetry for practical SOC monitoring.
V1	AWS, Azure, Google Workspace, Fortinet, Palo Alto, Cisco, Sophos, SentinelOne, CrowdStrike, vulnerability scanners	Enable MDR/XDR and wider enterprise coverage.
V2	Okta, Cloudflare, Zscaler, GCP, email security platforms, Slack, advanced ticketing sync	Broaden identity, edge, cloud and collaboration coverage.
Enterprise/Sovereign	Sector-specific APIs, banking/payment logs, telecom/utility/OT feeds, regulator reporting APIs	Support high-value regulated and critical infrastructure propositions.

7. Security architecture controls

Control area	Requirements
Tenant isolation	Every query, object, file, vector embedding and action must be scoped to tenant. Include isolation tests in CI/CD.
Encryption	TLS for all transport; KMS-managed encryption for databases/object stores; encrypted secrets.

Secrets	Use Vault/cloud secret manager; no connector credentials in logs; rotation support per tenant.
Admin controls	Break-glass roles, privileged action approval, session logging and just-in-time access where possible.
Audit logs	Immutable append-only audit events for login, admin, analyst, AI and SOAR actions.
AI privacy	Tenant-scoped prompts, no cross-tenant context leakage, prompt/result logging, configurable data minimisation.
Data retention	Retention per tenant/tier; legal hold and evidence preservation; deletion workflows.
Backup/DR	RPO/RTO by tier, tested restore, separate backup encryption and disaster recovery runbooks.

8. DevSecOps and environments

Environment	Purpose	Controls
Development	Feature build and unit testing	Synthetic data only, no production secrets.
Integration/UAT	Connector testing and business validation	Masked data, controlled access, test tenants.
Staging	Production-like testing before release	Security scan gates, migrations tested, rollback plan.
Production	Live SOC service	MFA, least privilege, monitored admin, immutable audit logs.
DR/Backup	Recovery and continuity	Separated credentials, regular restore test, documented runbook.

Reference standards and sources

NIST Cybersecurity Framework 2.0: <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>

NIST SP 800-61 Revision 3 Incident Response Recommendations: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>

OCSF Open Cybersecurity Schema Framework: <https://ocsf.io/>

Sigma Detection Format: <https://sigmahq.io/docs/basics/rules.html>

OASIS STIX/TAXII Cyber Threat Intelligence Standards: https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=cti

CIS Critical Security Controls v8.1: <https://www.cisecurity.org/controls/v8-1>

FIRST Traffic Light Protocol 2.0: <https://www.first.org/tlp/>